RBAC, Separation of Duties & Access Requests

Week 3 · Care Access Navigator · HealthLine Regional Medical Center (HRMC)

Role-based access model, least privilege, separation of duties and the access-request workflow, as enforced and tested on the live Keycloak realm

Author	Akhila Chennamaneni
Date	November 4, 2026
Version	v1.0
Enforcement	7 job-function groups, one realm role each; 4 sign-in gates (live since 11/03/2026)
Tested	EV-13 (before/after) and end-to-end TC-01, TC-02, TC-03, TC-07
Workbook	03_IAM_Lab/CAN_DOC_RBAC_SoD_Access_Request_v1.0.xlsx

Day	Board item	Section	Status
Mon	Design healthcare RBAC model	1 RBAC matrix	**Done**
Tue	Apply least privilege and separation-of-duties rules	2 and 3	**Done**
Wed	Design access request and approval workflow	4 workflow + register	**Done**
Thu	Implement and test RBAC roles	EV-13, TC-01/02 (done 11/03)	**Done**

1. RBAC matrix

Rows are the seven job roles; each is granted by exactly one Keycloak group. A cell shows what the role may do in that application; **Denied** means the application's sign-in gate refuses the role (tested). Token contents match: each client's scope mapping carries only its allowed roles.

Role / group	ehr-simulator	patient-portal	billing-app	hr-app	MFA
clinician Clinicians	Read/write full chart, orders, notes	Read/reply to patient messages	Denied	Denied	-
nurse Nurses	Read chart; document vitals, meds given (no orders)	Read/reply to messages	Denied	Denied	-
billing Billing	Denied	Denied	Charges, claims, payments (cardholder data)	Denied	Required
hr HR	Denied	Denied	Denied	Workforce records, onboarding/offboarding	-

Role / group	ehr-simulator	patient-portal	billing-app	hr-app	MFA
it-support IT-Support	Denied	Denied	Denied	Sign-in allowed by the live gate (see finding LP-01)	Required
security-analyst Security-Analysts	Denied	Denied	Denied	Denied	Required
vendor Vendors	Denied	Denied	Denied	Denied	-

Application	Data	Classification
ehr-simulator	ePHI (clinical)	Restricted
patient-portal	ePHI (patient-facing)	Restricted
billing-app	PHI (demographics, codes) + PCI cardholder data	Restricted
hr-app	Workforce PII	Confidential

2. Least privilege

Role	Needs	Granted	Excluded	Assessment
clinician	Diagnose, treat, document	EHR + Portal	Billing, HR; any admin function	**Matches**
nurse	Care delivery under orders	EHR + Portal (no orders - design)	Billing, HR; orders	**Matches**
billing	Bill and collect	Billing app only, MFA	EHR clinical notes, Portal, HR	**Matches**
hr	Workforce administration	HR app only	All patient-facing apps	**Matches**
it-support	Account status, password resets	HR app sign-in, MFA	Clinical, billing and HR data (per role description)	Gap LP-01: HR app sign-in conflicts with 'no standing access to HR data'
security-analyst	Investigate security events	No application; logs/SIEM only, MFA	All application data	**Matches**
vendor	Defined engagement only	No application by default; time-boxed per request	Everything not in the request	Matches (test.vendor1 end date open: CA-08)

Finding: Finding **LP-01**: the IT-Support role description (stored on the Keycloak role) says no standing access to HR data, but the hr-app client scope and sign-in gate admit it-support. Either narrow IT-Support to an account-administration function without HR records, or update the role description with the business reason. Tracked as corrective action CA-18 (owner: HR Manager + IAM Analyst). Not changed on the live realm without the owner's decision.

3. Separation of duties

Policy: one job role per person. These pairs are the reason; the access review flags any account holding two roles (MULTIPLE_ROLES_SOD_CHECK), and CAN-ID-005 alerts on the group change. TC-07 proved both on 11/03 (vendor added to Billing: alerted High, flagged, removed).

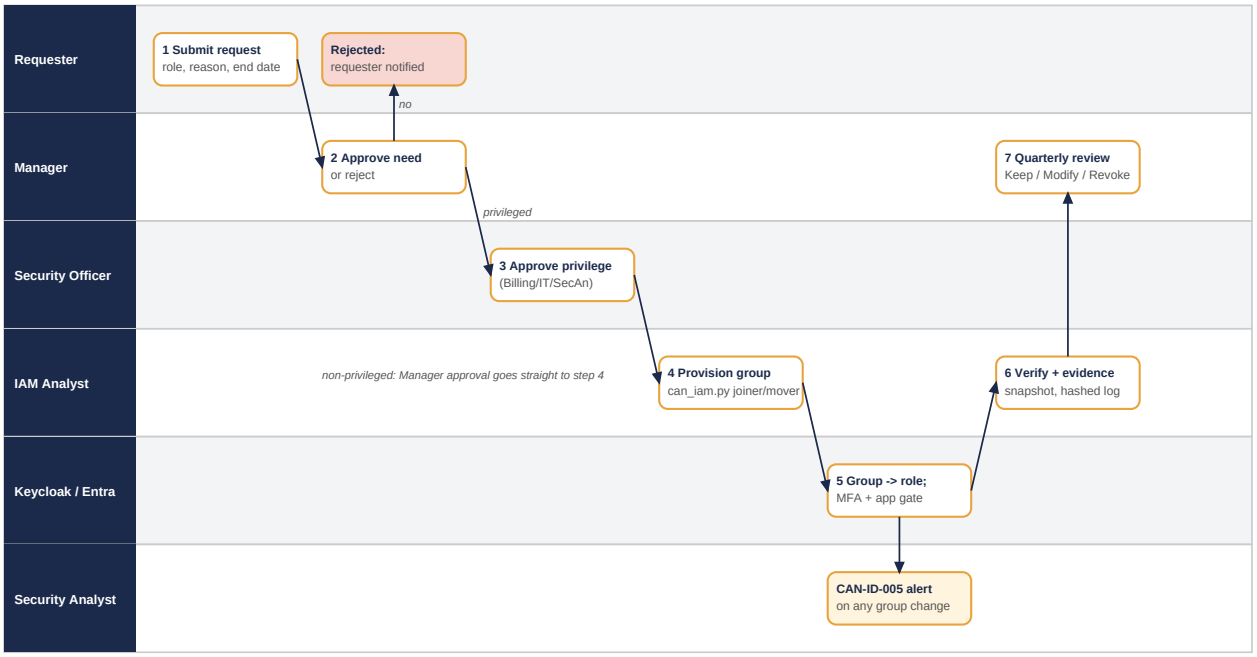
Role A	Role B	Why toxic	Risk
billing	clinician	Could record a service and bill for it (false claims)	High
billing	nurse	Could document care and bill for it	High
billing	it-support	Could reset another biller's password and post payments as them	High
hr	it-support	Could create a workforce record and grant the account access: joiner without independent approval	High
security-analyst	it-support	Could change accounts and also review the alerts about those changes	High

Role A	Role B	Why toxic	Risk
security-analyst	billing	Could investigate alerts about their own billing activity	Medium
vendor	*any workforce role	External party with internal standing access	High
clinician	nurse	Not toxic, but redundant: one person holds one clinical role	Low

Step	Performed by	Separation rule
Request	Requester (person or manager)	Cannot approve their own request
Approve	Manager; + Security Officer for privileged roles	Approver is not the requester and not the provisioner
Provision	IAM Analyst (can_iam.py)	Provisions only approved tickets; cannot approve
Verify / review	Manager / application owner (quarterly)	Reviewer is not the IAM Analyst who provisioned
Monitor	Security Analyst	Alerts on membership changes (CAN-ID-005), independent of IAM

4. Access request and approval workflow

Access request and approval workflow (REQ- joiner / CHG- mover / TERM- leaver)



Full-size diagram: 02_Diagrams/02_Workflows/CAN_DGM_Access_Request_Workflow_v1.0.pdf

- **Every request has a ticket**: REQ- (joiner), CHG- (mover), TERM- (leaver). Vendors must give an end date; can_iam.py refuses a vendor joiner without one.
- **Two approvals for privileged roles** (Billing, IT-Support, Security-Analysts): manager for the need, Security Officer for the privilege. OTP enrolment is forced at first sign-in.
- **Provisioning is by group only**, through can_iam.py, which writes ticket, approver and before/after state to a hashed audit log; a mover loses old access before gaining new.
- **Verification**: snapshot of groups/roles/sessions and a sign-in test; the quarterly review re-certifies.

5. Access-request register

11 requests, read from the JML log and the can_iam.py audit logs.

Ticket	Type	Login	Before → after	Approved by
REQ-2026-0101	Joiner	test.clinician	no account -> Entra user created; app role Clinician; Keycloak entra-id.test.clinician auto-created with role ...	Manager (JML-LOG)
CHG-2026-0201	Mover	test.nurse	app role Nurse; Keycloak role nurse -> app role Billing; sessions revoked; Keycloak role billing only (nurse r...	Manager (JML-LOG)

Ticket	Type	Login	Before → after	Approved by
TERM-2026-0301	Leaver	test.billing	enabled; app role Billing; Keycloak role billing -> Entra account disabled; sessions revoked; app role removed...	Manager (JML-LOG)
REQ-2026-0501	Joiner (test account)	test.billing2	no account -> Billing	IAM Analyst (W5 test plan)
REQ-2026-0502	Joiner (test account)	test.clinician2	no account -> Clinicians	IAM Analyst (W5 test plan)
REQ-2026-0601	Joiner	test.clinician3	no account -> Clinicians	clinical.manager1
REQ-2026-0602	Joiner	test.nurse2	no account -> Nurses	nurse.manager1
CHG-2026-0602	Mover	test.nurse2	nurse -> Billing	billing.manager1
TERM-2026-0602	Leaver	test.nurse2	billing -> disabled; no groups	billing.manager1
REQ-2026-0603	Joiner	test.vendor2	no account -> Vendors	it.manager1
TERM-2026-0603	Leaver	test.vendor2	vendor -> disabled; no groups	it.manager1